



UNIVERSIDAD DE ORIENTE

Facultad De Arquitectura E Ingeniería

Ingeniería En Desarrollo De Software

Cátedra

Ciberseguridad

Actividad Evaluativa

Laboratorio I

Informe de gestión de riesgos de seguridad de la información

Catedrático

Ing. Rolando Josías Colato Aparicio

Ciclo:

I-2026

Estudiante

Marilyn Michelle Jiménez Arias (U20231085)

SAN MIGUEL, 01 de marzo de 2026

ÍNDICE

INTRODUCCIÓN	3
PASO 1: IDENTIFICACIÓN DE ACTIVOS.....	4
1.1 Bases de Datos Institucionales.....	4
1.2 Aplicaciones en Desarrollo y Producción	4
1.3 Infraestructura en la Nube	4
PASO 2: IDENTIFICACIÓN DE AMENAZAS	5
2.1 Amenazas para Bases de Datos	5
2.2 Amenazas para Aplicaciones.....	5
2.3 Amenazas para Infraestructura en la Nube	5
PASO 3: IDENTIFICACIÓN DE VULNERABILIDADES	6
3.1 Vulnerabilidades en Bases de Datos	6
3.2 Vulnerabilidades en Aplicaciones	6
3.3 Vulnerabilidades en la Nube	6
PASO 4: ANÁLISIS DEL RIESGO.....	6
4.1 Análisis por Activo.....	6
4.2 Análisis General	7
PASO 5: EVALUACIÓN DEL RIESGO (MATRIZ DE CALOR).....	7
PASO 6: TRATAMIENTO DEL RIESGO	8
PASO 7: DOCUMENTACIÓN	8
PASO 8: MONITOREO Y REVISIÓN.....	9
10. CONCLUSIÓN	10

INTRODUCCIÓN

*El presente informe es un ejercicio académico **elaborado con fines de aprendizaje**. Se ha creado un escenario ficticio basado en "Universidad de Oriente (UNIVO)" y sus sistemas de información (Portal UNIVO, SGA, SIF, entre otros). Cualquier similitud con instituciones reales es mera coincidencia y **no representa un análisis oficial** de ninguna universidad existente.*

En la **Universidad de Oriente (UNIVO)** se maneja diariamente información muy importante de todos los estudiantes. Como alumno de esta universidad, sé que cuando me inscribo a materias, reviso mis notas en el portal o pago mi mensualidad, estoy compartiendo datos personales que deben estar protegidos.

Actualmente, la universidad almacena:

- **Datos personales:** Nombres completos, número de DUI, dirección de casa, teléfonos y correos electrónicos de todos los estudiantes con una cantidad bastante amplia de estudiantes activos.
- **Expedientes académicos:** Historial de materias cursadas, calificaciones, promedio, récord de matrícula, constancias y actas de grado.
- **Información financiera:** Registro de pagos de matrícula y mensualidades, estado de cuenta, becas otorgadas por la universidad y convenios de pago.

El responsable directo de velar por la seguridad de esta información es el Oficial de Seguridad de la Información (CISO) de la UNIVO. Su función principal es identificar los riesgos que puedan afectar la confidencialidad, integridad y disponibilidad de los datos, y proponer soluciones para mitigarlos.

Este informe desarrolla un análisis completo de gestión de riesgos siguiendo 8 pasos: identificación de activos, amenazas, vulnerabilidades, análisis del riesgo, evaluación, tratamiento, documentación y monitoreo. El objetivo final es reducir el nivel de riesgo actual de Crítico a un nivel aceptable Medio o Bajo.

PASO 1: IDENTIFICACIÓN DE ACTIVOS

Un **activo de información** es todo recurso con valor para la UNIVO que debe ser protegido. Se identifican tres categorías críticas:

1.1 Bases de Datos Institucionales

Repositorios centrales de información estructurada:

- **Base de Datos del SGA (Sistema de Gestión Académica):** Contiene datos personales (DUI, dirección, teléfonos, correo) e historial académico (calificaciones, materias cursadas, promedio, récord de matrícula). Es la más utilizada a través del Portal UNIVO.
- **Base de Datos del SIF (Sistema Integrado Financiero):** Almacena pagos, aranceles, estado de cuenta, becas, convenios y deudas. Conectada con el SGA para validar pagos antes de matrícula.
- **Base de Datos del Portal UNIVO:** Capa de datos que alimenta directamente el portal web de uso diario para estudiantes.

1.2 Aplicaciones en Desarrollo y Producción

Sistemas que permiten acceder y gestionar la información:

Aplicaciones en Producción:

- **Portal UNIVO:** Página web principal para estudiantes. Permite consultar calificaciones, inscripción a materias, horarios, estado de cuenta y actualizar datos personales. Crítico en épocas de matrícula.
- **Portal Docente UNIVO:** Usado por profesores para subir calificaciones, pasar asistencia y comunicarse con estudiantes.
- **Sistema Administrativo Interno (SAI):** Herramienta para personal de Registro Académico, Finanzas y Bienestar Estudiantil en trámites, constancias, pagos y actualización de registros.

Entorno de Desarrollo:

- **Laboratorio de Desarrollo UNIVO:** Servidores de prueba donde el equipo de sistemas prueba nuevas funcionalidades y corrige errores antes de implementarlas en producción.

1.3 Infraestructura en la Nube

Servicios contratados con proveedores como AWS, Azure o Google:

- **Correo Institucional UNIVO:** Correo para estudiantes y docentes (Office 365 o Google Workspace) para comunicaciones oficiales y notificaciones académicas.

- **Almacenamiento de Respaldos (Backups):** Copias de seguridad diarias de bases de datos y sistemas críticos guardadas en la nube para garantizar disponibilidad ante desastres.
- **Servidores Virtuales:** Alojamiento de algunas aplicaciones y servicios en la nube para acceso desde cualquier lugar y facilidad de mantenimiento.

PASO 2: IDENTIFICACIÓN DE AMENAZAS

2.1 Amenazas para Bases de Datos

1. **Ransomware:** Un virus que encripta la información del SGA y SIF, exigiendo rescate económico. En épocas de exámenes o matrícula, esto paralizaría por completo la universidad.
2. **Inyección SQL:** Atacantes aprovechan formularios del Portal UNIVO (búsqueda de cursos, inscripción) para ejecutar comandos maliciosos y extraer toda la información de la base de datos.
3. **Filtración por empleados:** Personal de Registro Académico o Finanzas, intencionalmente o por accidente (ej. enviando archivos a correo personal), podría filtrar datos masivos de estudiantes.

2.2 Amenazas para Aplicaciones

1. **Ataque DDoS:** Durante la semana de matrícula, un ataque podría saturar el Portal UNIVO, dejando a miles de estudiantes sin poder inscribirse.
2. **Robo de contraseñas:** Muchos usuarios repiten contraseñas. Si se filtran en otros sitios, los atacantes prueban esas mismas combinaciones en el portal.
3. **Explotación de errores en el código:** Si el equipo de desarrollo no revisa el código a fondo, quedan "puertas abiertas" que los atacantes aprovechan.

2.3 Amenazas para Infraestructura en la Nube

1. **Configuración incorrecta de permisos:** Si el administrador configura mal el almacenamiento de backups y lo deja "público", cualquiera en internet podría descargarlos.
2. **Robo de credenciales del administrador:** Correos falsos (phishing) al encargado de sistemas podrían robar la contraseña de la cuenta de administración de la nube.
3. **Interrupción por falla del proveedor:** Servicios como AWS o Azure pueden tener fallas técnicas que dejen sin acceso al correo institucional o aplicaciones.

PASO 3: IDENTIFICACIÓN DE VULNERABILIDADES

3.1 Vulnerabilidades en Bases de Datos

- **Falta de cifrado en reposo:** La información se guarda "en texto plano". Si alguien copia los archivos de la base de datos, puede leer todo como si fuera un Excel.
- **Contraseñas débiles o compartidas:** Se usan claves fáciles ("admin123") o varios administradores comparten la misma contraseña.
- **Falta de segmentación de red:** Servidores web y de bases de datos están en la misma red. Si un atacante compromete el servidor web, tiene acceso directo a la base de datos.

3.2 Vulnerabilidades en Aplicaciones

- **Ausencia de autenticación multifactor (MFA):** Solo se requiere usuario y contraseña. No hay verificación en dos pasos (código al celular).
- **Código no auditado:** Nuevas funcionalidades se implementan sin revisión de seguridad previa.
- **Manejo inadecuado de sesiones:** Las sesiones pueden quedar abiertas por horas aunque el usuario cierre el navegador.

3.3 Vulnerabilidades en la Nube

- **Puertos abiertos innecesarios:** Puertos de administración remota (ej. puerto 22) abiertos a todo internet, expuestos a ataques de fuerza bruta.
- **Uso de cuentas de administrador compartidas:** Varias personas usan la misma cuenta, imposibilitando saber quién hizo qué.
- **Falta de monitoreo de configuraciones:** Nadie revisa periódicamente cómo están configurados los servicios. Un error puede pasar desapercibido por meses.

PASO 4: ANÁLISIS DEL RIESGO

Para analizar el riesgo, combinamos dos factores:

Probabilidad: ¿Qué tan probable es que ocurra la amenaza? (Baja, Media o Alta)

Impacto: ¿Qué tan grave sería para la UNIVO si ocurriera? (Bajo, Moderado o Crítico)

4.1 Análisis por Activo

Bases de Datos (SGA y SIF):

- **Probabilidad:** ALTA. Están expuestas a internet a través del Portal UNIVO y tienen vulnerabilidades importantes como falta de cifrado y contraseñas débiles.

- **Impacto:** CRÍTICO. Contienen la información más sensible de todos los estudiantes: datos personales, académicos y financieros.
- **Nivel de Riesgo Inicial:** CRÍTICO

Aplicaciones (Portal UNIVO, Portal Docente, SAI):

- **Probabilidad:** MEDIA. Los ataques a aplicaciones web son muy comunes, pero algunas medidas básicas pueden estar funcionando.
- **Impacto:** ALTO. Si el portal se cae en época de matrícula, es un caos. Si alguien accede sin autorización, puede modificar notas o robar información.

Nivel de Riesgo Inicial: MEDIO-ALTO

Infraestructura en la Nube:

- **Probabilidad:** MEDIA. Los errores de configuración son muy comunes en entornos de nube.
- **Impacto:** ALTO. Una mala configuración podría exponer todas las copias de seguridad o permitir que un atacante tome el control.

Nivel de Riesgo Inicial: MEDIO

4.2 Análisis General

La UNIVO comienza con un **RIESGO INICIAL CRÍTICO**. Esto significa que es muy probable que ocurra un incidente grave que afecte la información de los estudiantes, con consecuencias muy serias para la institución.

PASO 5: EVALUACIÓN DEL RIESGO (MATRIZ DE CALOR)

Aquí visualizamos los riesgos en una matriz o "mapa de calor" con los siguientes colores:

- Verde: **Riesgo Bajo**
- Amarillo: **Riesgo Medio**
- Rojo: **Riesgo Crítico**

IMPACTO \ PROBABILIDAD	BAJA	MEDIA	ALTA
		NUBE (MEDIO)	BASES DE DATOS (CRÍTICO)
		APLICACIONES (MEDIO-ALTO)	

Ubicación de los activos:

- Bases de Datos: Rojo (Crítico)
- Aplicaciones: Naranja/Naranja (Medio-Alto)
- Infraestructura en la Nube: Amarillo (Medio)

PASO 6: TRATAMIENTO DEL RIESGO

Una vez identificados los riesgos, debemos proponer acciones concretas para reducirlos. A esto se le llama "tratamiento del riesgo".

ID	Riesgo (Amenaza)	Acciones de Tratamiento (Soluciones)	Responsable	Prioridad
R-01	Ransomware en Bases de Datos	1. Implementar copias de seguridad diarias que sean inmutables (que no se puedan modificar ni borrar). 2. Separar físicamente los servidores web de los servidores de bases de datos mediante VLANs y firewalls internos.	CISO / Equipo de Infraestructura	Alta
R-02	Inyección SQL en Portal UNIVO	1. Realizar revisiones de código (auditorías) antes de cada actualización del portal. 2. Implementar un WAF (Web Application Firewall) que filtre el tráfico malicioso.	Equipo de Desarrollo	Alta
R-03	Acceso no autorizado por robo de contraseñas	1. Activar autenticación multifactor (MFA) en todos los sistemas: Portal UNIVO, Portal Docente, Sistema Administrativo y correo institucional. 2. Establecer una política de contraseñas seguras y obligar a cambiarlas periódicamente.	Equipo de TI	Alta
R-04	Configuración incorrecta en la nube	1. Aplicar el principio de mínimo privilegio : dar a cada usuario solo los accesos estrictamente necesarios. 2. Revisar mensualmente las configuraciones de seguridad en la nube (buckets, permisos, grupos de seguridad).	Administrador de la Nube	Alta
R-05	Fuga de información (interna o externa)	1. Implementar cifrado en reposo para todas las bases de datos (que la información no se pueda leer aunque sea copiada). 2. Capacitar al personal administrativo y docente sobre buenas prácticas de seguridad.	CISO / RRHH	Media

Riesgo Residual (después de implementar las soluciones)

Después de aplicar todas las medidas propuestas, reevaluamos la situación:

- Bases de Datos: Bajan de CRÍTICO a MEDIO (el impacto sigue siendo crítico, pero la probabilidad se reduce significativamente).
- Aplicaciones: Bajan de MEDIO-ALTO a MEDIO.
- Infraestructura en la Nube: Baja de MEDIO a BAJO.

Riesgo General Residual: MEDIO-BAJO

PASO 7: DOCUMENTACIÓN

Este informe debe convertirse en un **documento formal** de la UNIVO.

¿Por qué es importante?

- **Queda constancia escrita** del análisis realizado y de las propuestas de mejora.
- **Sirve como evidencia** para auditorías internas y externas, demostrando que la universidad se preocupa por la seguridad de la información.

- **Debe ser aprobado por las autoridades** (Rectoría, Vicerrectoría, Dirección de TI) para que las acciones propuestas tengan respaldo institucional y presupuesto asignado.
- **Debe guardarse en un lugar seguro** y actualizarse al menos una vez al año, o cuando ocurran cambios significativos en los sistemas.

PASO 8: MONITOREO Y REVISIÓN

La seguridad no es algo que se hace una vez y se olvida. Hay que darle seguimiento constante. Aquí propongo las herramientas y el plan de seguimiento para la UNIVO.

Herramientas de Monitoreo Sugeridas

- **Wazuh:** Es un programa de código abierto que funciona como un "vigilante" de la red. Revisa constantemente los servidores en busca de actividades sospechosas, intrusiones o cambios no autorizados, y envía alertas en tiempo real.
- **Nessus (o OpenVAS):** Es un "escanéador de vulnerabilidades". Actúa como un chequeo médico para los sistemas: busca puntos débiles, configuraciones incorrectas, falta de parches de seguridad, contraseñas débiles, etc. Se recomienda ejecutarlo mensualmente.
- **Herramientas nativas de la nube:** AWS CloudTrail, Azure Monitor o Google Cloud Logging permiten ver todos los movimientos dentro de la infraestructura en la nube y detectar configuraciones inseguras.
- **Firewall de Próxima Generación (NGFW):** Es la puerta de entrada a la red de la UNIVO. Un buen firewall no solo bloquea accesos no autorizados, sino que también puede detectar y detener ataques antes de que lleguen a los servidores.

Plan de Seguimiento

FRECUENCIA	ACTIVIDAD
MENSUAL	Ejecutar escaneo de vulnerabilidades con Nessus o OpenVAS. Revisar los reportes y corregir los problemas más graves.
TRIMESTRAL	Reunión del equipo de seguridad (CISO, TI, Desarrollo) para revisar la matriz de riesgos, actualizar probabilidades y verificar el avance de los planes de acción.
SEMESTRAL	Realizar un simulacro de recuperación ante desastres (DRP): probar que las copias de seguridad realmente funcionan, restaurando toda la información en un entorno de prueba.
ANUAL	Contratar una auditoría externa de seguridad y pruebas de penetración (pentesting) para evaluar la efectividad de los controles implementados.

10. CONCLUSIÓN

Al comenzar este análisis, la **Universidad de Oriente (UNIVO)** presentaba un nivel de riesgo **CRÍTICO**. La información personal, académica y financiera de miles de estudiantes estaba expuesta a amenazas como ransomware, robo de datos a través del Portal UNIVO, filtraciones internas, ataques DDoS y errores de configuración en la nube.

Gracias a este ejercicio, hemos identificado las debilidades y propuesto soluciones concretas: autenticación multifactor (MFA), copias de seguridad inmutables, revisión de código, cifrado de bases de datos y capacitación al personal. Con estas medidas, el riesgo general se reduce a **MEDIO-BAJO**.

Se recomienda implementar estas acciones cuanto antes y darles seguimiento continuo, pues la seguridad de la información no es un destino, sino un proceso que requiere inversión, compromiso y la participación de toda la comunidad universitaria.